

UD2: Plan de Implantación y Protección de Datos

Bloques 4 · 5 | 15 horas

Marco normativo: RD 311/2022 ENS · RGPD (UE) 2016/679 · LOPDGDD LO 3/2018

Contexto UE: NIS2 · ISO/IEC 27001:2022 · ISO/IEC 27701:2025

**PLAN DE
SEGURIDAD**

RIESGO

CONTROL

RGPD

ENS

Contenidos de la Unidad

01

Plan de implantación de seguridad

Niveles, medidas de salvaguarda, hoja de ruta

02

Protección de datos de carácter personal

RGPD, LOPDGDD, AEPD, sanciones

03

Registro de actividades y documentación

RAT, DPIA, documento de seguridad

04

Caso práctico integrado

BIA → Plan implantación → Análisis cumplimiento RGPD

01

Plan de Implantación de Seguridad

Bloque 4 · GAP Analysis, medidas ENS, hoja de ruta

Determinación del nivel de seguridad existente vs. necesario

El punto de partida del plan de implantación es el GAP ANALYSIS: comparar el nivel de seguridad actual con el requerido por los procesos de negocio y la normativa aplicable.



ENS RD 311/2022 — La categoría del sistema (Básico/Medio/Alto) determina el conjunto mínimo de medidas del Anexo II que deben implantarse.

Marco de referencia: Anexo II RD 311/2022 — Medidas de Seguridad ENS

[ORG] Organización

- Política de seguridad
- Normativa interna
- Gestión de riesgos
- Roles y responsabilidades

[OP] Operacional

- Control de acceso
- Gestión de activos
- Gestión de cambios
- Continuidad del servicio

[MP] Protección

- Puestos de trabajo
- Redes
- Soportes
- Aplicaciones

Aplicación de medidas según categoría del sistema

Medida/Categoría	Básico	Medio	Alto
Política de seguridad	✓	✓	✓
Análisis de riesgos	—	✓	✓
Criptografía	—	✓	✓

1

Definir alcance y contexto

Sistemas incluidos, activos, normativa aplicable, partes interesadas.

2

Análisis del estado actual (GAP)

Inventario de controles existentes, nivel de madurez (CMM 0-5), brechas.

3

Diseño del plan de tratamiento

Priorización de controles (riesgo×coste), responsables, plazos.

4

Ejecución e implantación

Proyectos de seguridad, configuración, formación, cambios organizativos.

5

Verificación y revisión

Auditorías, indicadores KPI/KRI, revisión por dirección, actualización.

Documentos clave

- ▶ Política de Seguridad
- ▶ Plan de Tratamiento del Riesgo
- ▶ Plan Director de Seguridad
- ▶ Declaración de Aplicabilidad
- ▶ Informe de Auditoría
- ▶ Registro de Incidentes

02

Protección de Datos de Carácter Personal

Bloque 5 · RGPD, LOPDGDD, RAT, DPIA, sanciones

7 Principios del RGPD (art. 5)

Licitud, lealtad y transparencia — Base legal para tratar datos. Informar al interesado.

Limitación de finalidad — Datos recogidos para fines concretos, no reutilizables libremente.

Minimización — Solo los datos estrictamente necesarios para el fin.

Exactitud — Datos correctos y actualizados.

Limitación del plazo — Conservar solo el tiempo necesario.

Integridad y confidencialidad — Seguridad apropiada frente a accesos no autorizados.

Responsabilidad proactiva — Demostrar cumplimiento (accountability).

Derechos ARCO+ (art. 15-22)

A **Acceso:** Saber qué datos se tratan.

R **Rectificación:** Corregir datos inexactos.

S **Supresión:** 'Derecho al olvido'.

O **Oposición:** Oponerse al tratamiento.

+ **Portabilidad:** Recibir datos en formato estructurado.

+ **Limitación:** Restringir el tratamiento.

+ **No decisión auto.:** Oponerse a decisiones automatizadas.

El incumplimiento de la normativa de protección de datos puede conllevar sanciones económicas de gran calado, además de consecuencias reputacionales, penales y civiles.

Nivel	Infracción (ejemplos)	Sanción RGPD	Sanción LOPDGDD
LEVE	Incumplir medidas técnicas menores, pequeñas omisiones formales	—	Hasta 40.000 €
GRAVE	Incumplir principios básicos, tratar datos sin base legal, infracción derechos	Hasta 10 M€ / 2% facturación	Hasta 300.000 €
MUY GRAVE	Vulnerar principios fundamentales, transferencias internacionales ilegales	Hasta 20 M€ / 4% facturación	Hasta 20.000.000 €

⚠ NIS2 + Ley Coordinación Ciberseguridad: Responsabilidad solidaria del órgano de dirección. Inhabilitación temporal en infracciones graves reiteradas. Formación obligatoria de directivos.

Registro de Actividades de Tratamiento (RAT)

Obligatorio para responsables y encargados del tratamiento con >250 empleados, o que traten datos de riesgo (art. 30 RGPD).

- ☐ Nombre y datos del responsable
- ☐ Finalidades del tratamiento
- ☐ Descripción de categorías de interesados
- ☐ Categorías de datos personales tratados
- ☐ Destinatarios y transferencias internacionales
- ☐ Plazos de supresión previstos
- ☐ Descripción de medidas de seguridad (art. 32)

Evaluación de Impacto (DPIA/EIPD) — art. 35 RGPD

Obligatoria cuando el tratamiento sea susceptible de entrañar alto riesgo para los derechos y libertades de las personas.

¿Cuándo es obligatoria?

Perfilado sistemático, tratamiento a gran escala de datos sensibles, videovigilancia sistemática.

Contenido mínimo

Descripción del tratamiento, evaluación de la necesidad, riesgos para los interesados, medidas para abordarlos.

Consulta previa

Si el riesgo residual sigue siendo alto → consultar a la AEPD antes de iniciar el tratamiento.

DPD obligatorio: AAPP, organismos públicos, tratamientos a gran escala de datos sensibles.

Medidas de seguridad exigidas — art. 32 RGPD + ENS Anexo II

Técnicas

- ✓ Cifrado de datos en reposo y en tránsito
- ✓ Seudonimización cuando proceda
- ✓ Autenticación robusta (MFA)
- ✓ Control de acceso lógico (RBAC/ABAC)
- ✓ Monitorización y alertas (SIEM)
- ✓ Copias de seguridad y recuperación

Organizativas

- ✓ Política de seguridad de la información
- ✓ Procedimientos de gestión de incidentes
- ✓ Concienciación y formación del personal
- ✓ Acuerdos de confidencialidad (NDA)
- ✓ Contratos con encargados del tratamiento
- ✓ Gestión del ciclo de vida de los datos

Notificación de brechas de seguridad (art. 33-34 RGPD): A la AEPD en máximo 72 horas. A los interesados si el riesgo es alto (sin demora indebida). Documentar todas las brechas aunque no se notifiquen.

03

Caso Práctico Integrado

BIA → GAP → RAT → Plan Director

Escenario: empresa de 80 empleados que presta servicios cloud a AAPP y trata datos de salud de clientes.

1

BIA y clasificación CIA

Identificar los 5 procesos críticos del negocio. Valorar cada proceso en las dimensiones C/I/A/AT/T. Determinar la categoría ENS de los sistemas que los soportan.

2

Gap Analysis ENS

Revisar los controles existentes frente al Anexo II del RD 311/2022 para categoría Media. Identificar brechas. Priorizar acciones por riesgo residual.

3

Registro de tratamientos (RAT)

Identificar todos los tratamientos de datos personales. Cumplimentar el RAT. Determinar si algún tratamiento requiere DPIA (datos de salud → SIEMPRE).

4

Plan de implantación

Elaborar el Plan Director de Seguridad con hoja de ruta a 12/24/36 meses. Asignar responsables. Definir KPIs de seguimiento.

Resumen UD2

- 1 El Plan de Implantación parte del GAP Analysis entre el nivel de seguridad actual y el requerido por el negocio y la normativa
- 2 El ENS RD 311/2022 clasifica los sistemas en Básico/Medio/Alto y define las medidas obligatorias del Anexo II para cada categoría
- 3 El RGPD exige base legal, minimización, limitación de finalidad y medidas de seguridad proporcionales al riesgo (art. 32)
- 4 El RAT es obligatorio; la DPIA se requiere cuando el tratamiento puede suponer alto riesgo (datos de salud, perfilado, videovigilancia)
- 5 Las brechas de seguridad con datos personales deben notificarse a la AEPD en 72 horas; a los afectados si el riesgo es alto
- 6 Las sanciones RGPD alcanzan hasta 20 M€ o el 4% de la facturación mundial; NIS2 añade responsabilidad personal de directivos